TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) User-to-Admin via Admin Management Dashboard
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-26
Affected Asset	https://bertani.my.id/admin/users
Severity	**Medium**
CVSS Score	**5.4** **CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N**
Proof of Concepts	Please see Steps to Reproduce section

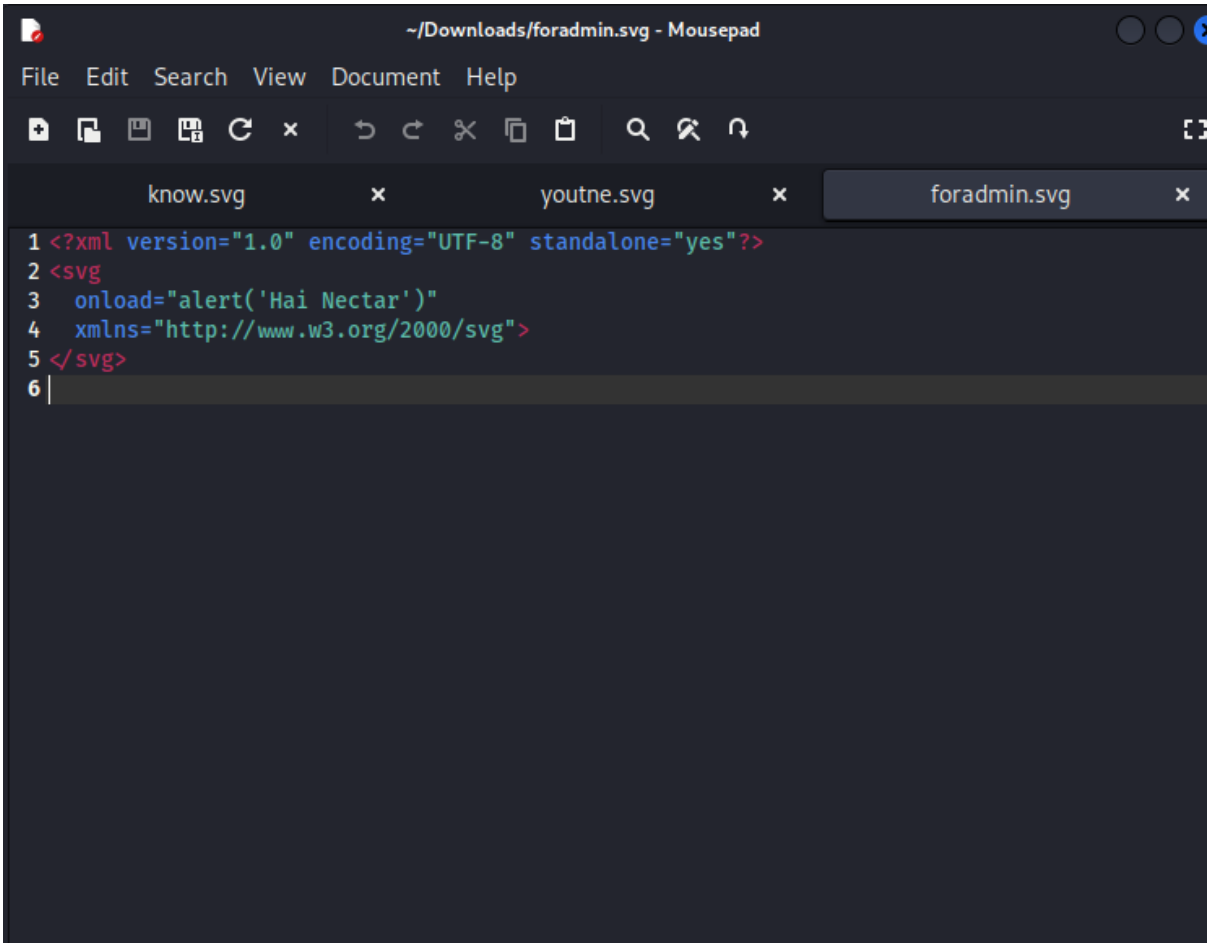
SUMMARY

Ditemukan kerentanan keamanan jenis Stored Cross-Site Scripting (XSS) pada fitur pembaruan profil pengguna. Celah ini terjadi karena sistem tidak melakukan validasi konten dan sanitasi terhadap file gambar berformat SVG yang diunggah sebagai avatar. Penyerang dapat menyisipkan kode JavaScript berbahaya ke dalam file SVG tersebut. Karena hanya pihak Administrator yang memiliki akses untuk melihat daftar seluruh pengguna beserta avatarnya di panel kontrol (/admin/users), skrip tersebut akan tereksekusi secara otomatis di browser Admin saat mereka memuat atau membuka file tersebut. Hal ini menciptakan risiko tinggi terhadap pengambilalihan akun administrator melalui pencurian *session cookies*

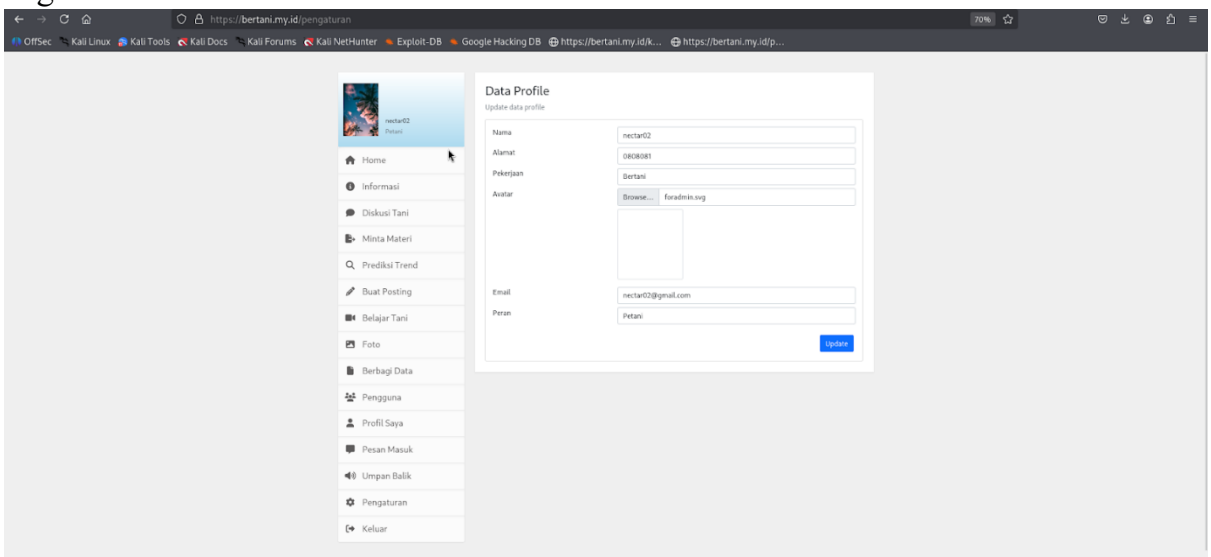
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

2. Buat file svg yang berisi

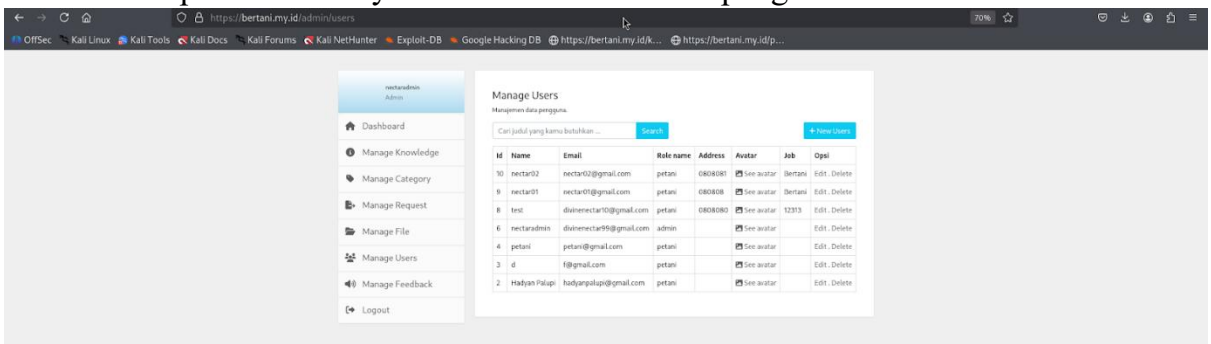


3. Masuk ke url https://bertani.my.id/pengaturan dan masukan file svg tersebut ke bagian avatar

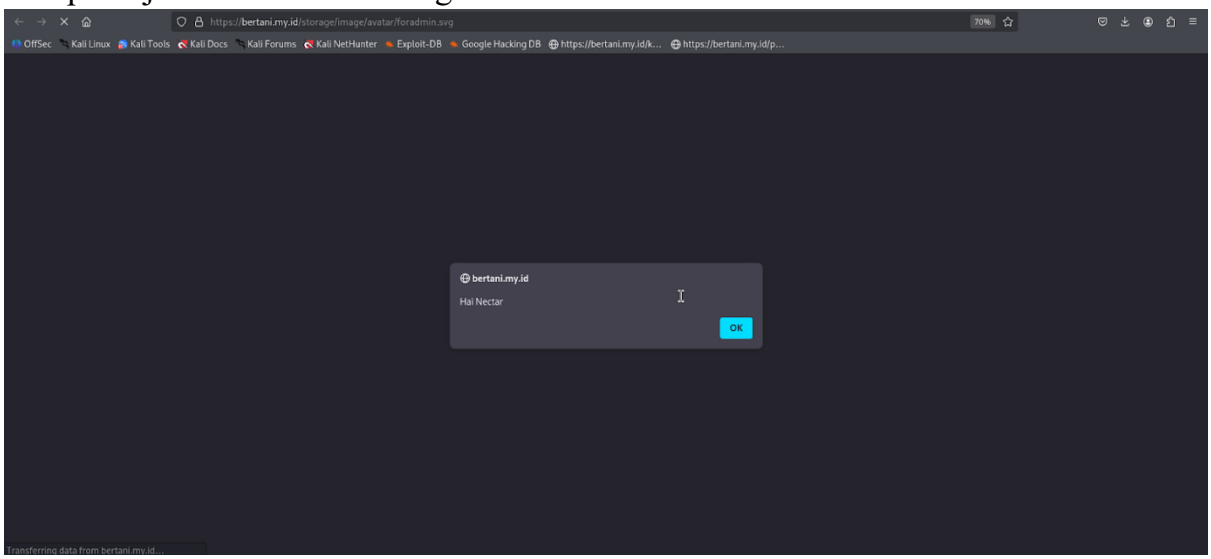


4. Login ke Akun Anda sebagai admin di URL https://bertani.my.id/login

5. Maka saat admin membuka gambar yang telah kita masukan tadi terus yang ada di url https://bertani.my.id/admin/users akan terpengaruh.



6. Tampilan jika admin menekan gambar



EXPECTED RESULT

Sistem seharusnya melakukan proses sanitasi dan pembersihan secara menyeluruh terhadap setiap file SVG yang diunggah oleh pengguna. Hal ini bertujuan untuk memastikan bahwa elemen berbahaya tidak tersimpan di server, sehingga saat Administrator mengakses halaman manajemen pengguna (/admin/users), tidak terjadi eksekusi skrip otomatis yang dapat mengompromi akun dengan hak akses tinggi tersebut.

ACTUAL RESULT

Aplikasi menerima dan menyimpan file SVG berbahaya tanpa validasi konten yang ketat. Akibatnya, saat Administrator membuka halaman daftar pengguna atau memuat gambar avatar tersebut, browser mengeksekusi kode JavaScript di dalamnya secara otomatis. Penyerang berhasil memicu jendela *alert* pada sisi Administrator, yang membuktikan adanya celah untuk mencuri data sesi admin

IMPACT

1. Admin Account Takeover: Dampak utama adalah pengambilalihan akun Administrator karena hanya pihak admin yang dapat memicu eksekusi *payload* ini melalui dashboard khusus.

2. Privilege Escalation: Penyerang tingkat rendah (Petani) dapat menyerang pihak dengan otoritas tertinggi di sistem.

3.Full System Compromise: Dengan mendapatkan *cookie* admin, penyerang memperoleh kontrol penuh atas seluruh basis data dan pengaturan platform Bertani.

RECOMMENDATION

Sanitasi Khusus Admin View: Pastikan setiap file yang ditampilkan di panel administrasi telah melalui proses pembersihan tag <script> dan atribut onload

REFERENCES

1. **PortSwigger - Stored XSS via SVG File:** https://portswigger.net/web-security/cross-site-scripting/stored
2. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload